

LAB 04

GlobalBank - Change Management Denetimi

Zorluk: Orta • Tahmini süre: 30-60 dakika • Rolünüz: IT Auditor

1. HİKÂYE

Sektör Uluslararası bankacılık	Ölçek 8.200 çalışan
BT ortamı Ana bilgisayar, Java servisleri, GitLab, ServiceNow	Dönem 01.04.2026-30.06.2026; 1.284 değişiklik

GlobalBank, mobil bankacılık kesintisi sonrasında Değişiklik Yönetimi sürecini denetim planına almıştır. Teknoloji yönetimi başarı oranının %98 olduğunu ve sürecin olgun çalıştığını savunmaktadır. Operasyon ekibi ise acil değişiklik sayısının arttığını belirtmektedir. Denetim örneklemenizde standart, normal ve emergency kayıtlar bulunur. Bir başarısız değişikliğin müşteri işlemlerini 47 dakika etkilediği görülür.

2. SİZE VERİLEN GÖREV

Değişikliklerin yetkilendirilmesi, test edilmesi, görevler ayrılığı, uygulama ve geri dönüş kontrollerini değerlendirin. Tek bir başarısızlığı genellemeden popülasyon ve örneklem yaklaşımınızı açıklayın.

3. OLAYLAR VE KANITLAR

E-01 | Politika CHG-01

Normal değişiklikler uygulama öncesi iş sahibi, teknik sahibi ve CAB tarafından onaylanır. Emergency değişiklikler olay yöneticisi onayıyla uygulanabilir; 2 iş günü içinde geriye dönük CAB incelemesi zorunludur.

E-02 | CHG-2026-1842

Tür: Emergency; talep: Mehmet Kaya; uygulama: 14.06 23:10; olay yöneticisi onayı: 14.06 23:02; CAB review: yok; test kanıtı: yok; sonuç: başarılı. Açıklama: ödeme servisinde kritik bellek problemi.

E-03 | CHG-2026-1761

Tür: Normal; geliştirici ve uygulayan: aynı kişi; test sonucu ekli; iş sahibi onayı var; CAB onayı var. Üretim logları geliştiricinin kişisel hesabıyla deployment yaptığını gösterir.

E-04 | CHG-2026-1907

Tür: Normal; tüm onaylar mevcut; test ekran görüntüsü değişiklik tarihinden 5 gün sonradır. Süreç sahibi ekran görüntüsünün yanlış dosyayla değiştirildiğini söylemiştir.

LAB 04

GlobalBank - Change Management Denetimi

Zorluk: Orta • Tahmini süre: 30-60 dakika • Rolünüz: IT Auditor

3. OLAYLAR VE KANITLAR - DEVAM

E-05 | Başarısız değişiklik CHG-2026-1710

Rollback planı: 'önceki sürüme dön'. Rollback 31 dakika sürmüştü; hedef 10 dakikadır. Post implementation review yapılmış ve kapasite testi aksiyonu atanmıştır.

E-06 | Popülasyon analizi

1.284 kaydın 96'sı emergency (%7,5). Önceki çeyrek %2,1. Emergency kayıtların 61'inde geriye dönük CAB alanı doludur. Süreç yöneticisi bazı review'ların toplantı notunda tutulduğunu belirtir.

E-07 | CAB tutanağı

Seçilen üç haftanın toplantı tutanağında katılımcılar ve kararlar vardır. CHG-2026-1842 listelenmemiştir. Diğer iki emergency kayıt kayıt numarası olmadan sözlü olarak görüşülmüştür.

4. ÖĞRENCİNİN GÖREVLERİ

- Denetim amacı, kapsamı ve ana riskleri tanımlayın.
- Emergency oranındaki artışı yorumlamak için hangi analizleri yaparsınız?
- Üç değişiklik kaydının kanıtlarını ayrı ayrı değerlendirin.
- Geliştiricinin üretim erişimini SoD ve operasyonel gereklilik açısından tartışın.
- Rollback kontrolünün tasarım ve etkinliğini değerlendirin.
- Popülasyondan ek örneklem seçme yönteminizi açıklayın.
- En önemli bulguyu durum-kriter-neden-etki-öneri formatında yazın.

5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- Denetim kapsam ve risk notu
- Örneklem yaklaşımı
- En az 3 kontrol sonucu
- 1 tam audit finding
- Önceliklendirilmiş aksiyon listesi

ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:

volkan@grcustasi.com

adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM
GRC Ustası